

packet. On doing so, the sniffer computer receives the packet. Having said that, if a packet-monitoring software is run on the destination computer, it will show that the packets are coming from this sniffer computer, which in reality is not the case. Thus, the hackers are successful in hiding themselves, and at the same time collecting packet information from the sniffer computer, because their own real source IP is nowhere revealed in this process.

Now let's understand why hackers prefer spoofing. While hiding on the network is the very first step, a hacker's intention is always beyond that. By collecting packets on the sniffer computer, hackers can gain a lot of information about the target machine. Vital information, such as open ports, type of operating system, layer 7 applications, cryptography types used, etc. can be collected, while not revealing one's identity. Just as an example, a hacker can send a spoofed packet to find out if the target is running a Web server. Once the port information is revealed on the sniffer, another chunk of spoofed packets can be sent to the target to establish a telnet session, and check Web server headers, which would reveal OS information as well as the type of Web server and security support information. Please note that the hackers need not always have access to the sniffer machine; in fact, using an advanced packet-sniffing tool can help the attackers use only their own machine, send spoofed packets, collect data on the same machine, and still be invisible on the network from an attack viewpoint.

Advanced hackers can use spoofing to find out the state of a firewall too. As we know, the firewall is a stateful packet-filtering process, which works on a set of configurable rules, to decide which packet should be allowed, and which dropped. When a source machine tries to connect to another machine that is protected behind a firewall, the source machine has to first establish a TCP handshake with the firewall. If the connection is allowed, the firewall itself establishes another connection with the destination machine, and the data transfer occurs with the firewall as a catalyst in this whole process. Also, when the destination machine tries to send an acknowledgement to the source, the firewall is bound to intercept and check whether or not a corresponding request from the source is pending. If it is not, the packet is dropped. All this is true for modern stateful firewalls, but not for old or cheap firewalls, which tend to allow ACK packets, thus exposing spoofing possibilities.

There are three reasons worth mentioning here, which typically make a network vulnerable to spoofing attacks. The first is, the IP packets can be modified very easily using free utilities available. The second reason is that even today, many applications still use source and destination IP address combinations as a secure way of authenticating a packet. Just as an example, there are Web servers that allow or disallow HTTP requests from a list of configurable IP

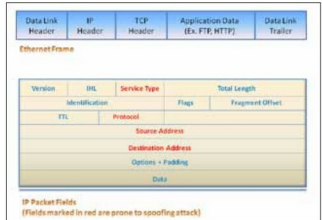


Figure 1: Ethernet network packet

addresses. Such systems prove to be useless if the packet is spoofed to reflect an IP address which is in the list of allowed IPs. The third reason is that the routers forward traffic based on the destination address, and by default do not care much about the source address.

Packet spoofing types

With this basic knowledge of how spoofing works, let us now dig a bit deeper. At a broad technical level, there are two basic types of spoofing: 'blind' spoofing and 'non-blind' spoofing. As we discussed earlier, the packet sequence number and acknowledgements help data transfer, so sensing those fields is an important requirement of a spoofing-based attack. In the blind spoofing type of attack, the attacker sends multiple packets to the target to sample the sequencing numbers. Once the pattern is found out, it becomes easy for the attacker to create another set of spoofed packets, to collect the data being transferred. Whereas, in the non-blind type, the attackers must be on the same subnet as the target, to be able to easily see the sequencing numbers and acknowledgements. Once they get their hands on it, they can break the established connection between the target and the other computer to which it is talking, and re-establish the connection by modifying the sequence numbers to that of the attackers' own machine. An extended version of this type of attack is the man-in-the-middle attack, whereby an entire session is stolen to decipher and steal data.

Now let's take a look at how the basic concept of spoofing could be used by hackers to impact various TCP-based application services.

IP port spoofing: In this type, the source port is modified in order to cheat the NAT devices and firewalls, and also to hide deep in the network. A firewall that is not very well managed can end up leaving stale rules in action, which can potentially lead certain outgoing ports on certain IP addresses to be open. IP port spoofing attacks take advantage of this situation. This is a serious attack, because the hacker can be outside the network, and still be able to